



UNIVERSITÉ D'ABOMEY-CALAVI
Institut de Formation et de Recherche en Informatique (IFRI)
Gestion des risques et incidents

TP N°3 — ANALYSE DES RISQUES EBIOS RM

Startup de microcrédit mobile — Bénin

Rapport complet — Ateliers 1 à 5

Module	Gestion des risques et incidents
Enseignant	M. Augustin ZOUMENOU
Année académique	2025 – 2026

Membres du groupe
AKIBODE Klervie
EHAHOUN-AGOSSOU
GANSE Gille-Christ
MEDJA Jerry Smith
ZANNOU Précieux

Contexte : Startup de microcrédit mobile proposant des services financiers via application Android/iOS, API REST Node.js, base PostgreSQL hébergée sur AWS. Opérant sous réglementation BCEAO/UEMOA et soumise à la loi APDP (Bénin).

Atelier 1 — Cadrage et socle de sécurité

1.1 Périmètre EBIOS RM — Missions et valeurs métier

La startup a pour mission de fournir des services de microcrédit mobile accessibles, rapides et conformes à la réglementation financière ouest-africaine, permettant à des particuliers et petits commerçants d'accéder à du crédit via leur smartphone.

Valeur métier	Description	Criticité
Données clients	Identité, scoring crédit, historique, données biométriques	Très haute
Portefeuille de créances	Dossiers de prêts, encours, remboursements	Très haute
Réputation & conformité	Conformité APDP/BCEAO, confiance des clients	Haute
Disponibilité des services	Accès 24h/7j à l'app mobile et aux paiements	Haute
Algorithme de scoring	Modèle propriétaire d'évaluation du risque crédit	Haute

1.2 Biens supports

Bien support	Type	Valeurs métier associées
Application Android/iOS	Logiciel	Données clients, disponibilité
API REST (Node.js)	Logiciel	Toutes valeurs métier
Base de données PostgreSQL	Données	Données clients, créances
Backoffice web	Logiciel	Gestion créances, conformité
Infrastructure AWS (EC2, RDS, S3, VPC)	Infrastructure	Disponibilité, confidentialité
Système d'authentification (JWT/OAuth)	Logiciel	Données clients
Canaux de communication (SMS, e-mail)	Réseau	Disponibilité, clients

1.3 Parties prenantes et niveaux de confiance

Partie prenante	Rôle	Confiance	Justification
Équipe interne (dev, ops, direction)	Exploitation et développement du SI	Élevé	Accès justifié, contrôlé par contrat et politique interne
BCEAO	Autorité de régulation financière	Élevé	Institution publique, interaction réglementaire encadrée
APDP (Bénin)	Protection des données personnelles	Élevé	Autorité légale, audit formalisé
Investisseurs	Financement, gouvernance	Élevé	Accès limité aux données financières, NDA signé
AWS (hébergeur cloud)	Infrastructure d'hébergement	Moyen	Prestataire critique, SLA contractuel, certifications ISO/SOC
Partenaires paiement (MTN MoMo, Orange Money)	Traitement des transactions	Moyen	API tierces, protocoles sécurisés, contrat cadre
Prestataires développement externe	Développement ponctuel	Moyen	Accès temporaire au code, auditable, NDA requis
Agents terrain	Enrôlement et collecte client	Moyen	Formation requise, accès restreint aux données

Clients mobiles	Utilisateurs finaux de l'app	Faible	Environnement non maîtrisé, terminaux personnels
Tiers non identifiés (Internet)	Inconnu	Faible	Bots, scrapers, attaquants potentiels
Cybercriminels / fraudeurs	Acteur malveillant	Faible	Fraude, vol de données, attaques ciblées fintech
Menace interne (employé malveillant)	Acteur interne compromis	Faible	Accès privilégié détourné – risque élevé d'impact

1.4 Exigences réglementaires applicables

APDP – Agence de Protection des Données à Caractère Personnel (Loi n°2009-09 du 22 mai 2009)

Tout traitement de données personnelles doit être déclaré ou autorisé. Les personnes concernées doivent être informées et peuvent exercer leurs droits (accès, rectification, suppression). Les données KYC, le scoring de crédit, les numéros de téléphone et la géolocalisation sont soumis à obligation de déclaration. La conservation est limitée à la durée nécessaire et toute violation doit être notifiée à l'APDP.

BCEAO – Réglementation sur les services de paiement et l'inclusion financière (Instruction n°008-05-2015)

La startup doit obtenir un agrément ou opérer sous agrément d'un établissement partenaire, respecter des plafonds de transactions par profil client, mettre en place des procédures KYC proportionnées, conserver les données de transaction au moins 5 ans, et disposer d'un dispositif anti-fraude et de reporting d'incidents.

Exigence	Source	Mesure technique associée
Consentement explicite à la collecte de données	APDP	Mentions légales in-app, opt-in enregistré en base
Chiffrement des données personnelles au repos et en transit	APDP	AWS KMS (chiffrement RDS/S3), TLS 1.2+ sur toutes les API
Droit d'accès et d'effacement des données personnelles	APDP	API de gestion du profil client, procédure de purge
Notification des violations de données (72h)	APDP	Plan de réponse aux incidents, runbook de notification
KYC – vérification d'identité des clients	BCEAO	Vérification pièce d'identité + liveness check (biométrie)
Conservation des données de transaction (5 ans min.)	BCEAO	RDS avec politique de rétention + archivage S3 chiffré
Plafonds et limites de transactions par profil	BCEAO	Contrôles métier dans l'API REST, alertes en temps réel
Reporting des incidents de sécurité	APDP + BCEAO	CloudTrail + GuardDuty, escalade réglementaire
LCB-FT – lutte contre le blanchiment	BCEAO/UEM OA	Screening listes de sanctions, scoring comportemental
Disponibilité et continuité du service	BCEAO	Déploiement multi-AZ AWS, RTO/RPO définis et testés
Traçabilité des accès aux données sensibles	APDP + BCEAO	CloudTrail, logs applicatifs centralisés (SIEM)

Atelier 2 — Sources de risques

2.1 Sources de risques identifiées

#	Source de risque	Type	Motivation principale
SR1	Cybercriminel externe	Externe	Gain financier, fraude, revente de données sur le darkweb
SR2	Employé / initié malveillant	Interne	Vengeance, corruption, appât du gain
SR3	Concurrent déloyal	Externe	Espionnage industriel, sabotage concurrentiel
SR4	Hacktiviste / État	Externe	Déstabilisation, idéologie, pression politique
SR5	Prestataire externe compromis	Ext./Indirect	Accès non surveillé au code source ou à l'infrastructure via contrat de développement

2.2 Objectifs visés par chaque source de risque

SR1 — Cybercriminel externe

- Voler les données bancaires et personnelles des clients (noms, numéros de téléphone, historiques de crédit)
- Détourner des fonds via des transactions frauduleuses
- Revendre les bases de données sur le darkweb
- Déployer un ransomware pour exiger une rançon

SR2 — Employé / initié malveillant

- Exfiltrer la base clients vers un concurrent
- Manipuler les montants de crédits accordés à son profit
- Supprimer ou altérer des données pour effacer des preuves

SR3 — Concurrent déloyal

- Obtenir la liste clients et le portefeuille de crédit
- Perturber la disponibilité de l'application pour nuire à la réputation
- Espionner les algorithmes de scoring crédit

SR4 — Hactiviste / État

- Exposer publiquement des données sensibles de clients vulnérables
- Compromettre la conformité APDP/BCEAO pour provoquer des sanctions réglementaires
- Perturber l'accès au service pour des populations précaires

SR5 — Prestataire externe compromis

- Accéder au code source de l'API ou de l'algorithme de scoring
- Introduire une porte dérobée (backdoor) lors d'une intervention de développement
- Exfiltrer des données clients via des accès de maintenance non révoqués

Atelier 3 — Scénarios stratégiques

Un scénario stratégique décrit, de façon abstraite, comment une source de risques peut atteindre un objectif visé en exploitant la vulnérabilité d'un bien support. La probabilité est évaluée sur une échelle de 1 (quasi-impossible) à 4 (quasi-certain).

3.1 Échelle de probabilité

Note	Niveau	Signification
1	Minime	Scénario théorique, très peu probable dans ce contexte
2	Significatif	Scénario possible, des cas similaires ont été observés dans le secteur
3	Fort	Scénario probable, les conditions favorables sont réunies
4	Maximal	Scénario très probable, des incidents similaires sont fréquents

SS1 — Compromission de l'API REST par injection

Paramètre	Contenu
Source de risque	SR1 – Cybercriminel externe
Bien support ciblé	API REST (Node.js) exposée sur AWS
Vulnérabilité exploitée	Absence de rate limiting et de validation stricte des entrées ; jetons JWT à longue durée de vie sans rotation ; absence de WAF configuré pour détecter les injections SQL
Objectif visé	Violation massive de données personnelles (KYC, scoring, historique de crédit) ; Sanction APDP et perte de confiance client ; Revente sur le darkweb
Probabilité	3/4 — Fort
Justification	Les API REST de microcrédits mobiles sont des cibles privilégiées ; les injections SQL restent parmi les vulnérabilités les plus exploitées (OWASP Top 10). La startup étant jeune, les pratiques de sécurité du code peuvent être immatures.

SS2 — Exfiltration de données par un employé du backoffice

Paramètre	Contenu
Source de risque	SR2 – Initié malveillant
Bien support ciblé	Backoffice web + BDD PostgreSQL
Vulnérabilité exploitée	Absence de contrôle d'accès granulaire, pas de journalisation des accès
Objectif visé	Approbation frauduleuse de prêts fictifs ou surévalués ; Perte financière directe pour la startup ; Risque de complicité de blanchiment (LCB-FT BCEAO)
Probabilité	3/4 — Fort
Justification	Un employé légitime a accès au backoffice par nature. L'absence de logs d'audit et de règles de moindre privilège facilite une exfiltration discrète et difficile à détecter après coup.

SS3 — Attaque DDoS pour indisponibilité du service mobile

Paramètre	Contenu
Source de risque	SR4 – Hactiviste / Attaquant opportuniste
Bien support ciblé	Infrastructure AWS (serveurs d'application + API)
Vulnérabilité exploitée	Absence de protection anti-DDoS dimensionnée (AWS Shield Standard uniquement) ; pas de stratégie de basculement documentée ; dépendance unique à une région AWS (us-east-1)

Objectif visé	Rendre l'application indisponible lors d'une période clé (fin de mois, campagne)
Probabilité	2/4 — Significatif
Justification	Les attaques DDoS sont accessibles à bas coût. Cependant, cibler délibérément un concurrent reste risqué légalement pour l'attaquant. Le scénario est possible mais moins fréquent dans le contexte béninois.

SS4 — Exploitation d'une configuration AWS mal sécurisée

Paramètre	Contenu
Source de risque	SR3 – Concurrent déloyal
Bien support ciblé	Algorithme de scoring → API REST → Dépôts de code (S3 / repo)
Vulnérabilité exploitée	Accès non restreint aux dépôts de code source (secrets mal gérés) ; absence de DLP sur les postes développeurs ; prestataires de développement externe avec accès trop larges
Objectif visé	Accéder à l'infrastructure complète et aux sauvegardes de la base de données
Probabilité	2/4 — Significatif
Justification	L'algorithme de scoring est la valeur différenciatrice principale. Les prestataires de développement externe représentent un vecteur d'exfiltration réaliste. La startup étant jeune, elle n'est pas encore systématiquement ciblée.

3.2 Cartographie des scénarios

Probabilité	Scénarios	Sources impliquées	Priorité de traitement
3/4 — Fort	SS1 · SS2	SR1 (Cybercriminel) · SR2 (Initié)	HAUTE — à traiter en priorité
2/4 — Significatif	SS3 · SS4	SR4 (Hacktiviste) · SR3 (Concurrent)	MOYENNE — à surveiller

Atelier 4 — Scénarios opérationnels

Objectif de l'Atelier 4 : Pour chaque scénario stratégique retenu, décrire le chemin d'attaque pas à pas (kill chain), évaluer l'impact sur les critères DICT (Disponibilité, Intégrité, Confidentialité, Traçabilité), calculer la criticité et proposer des mesures de sécurité (préventive + détective/corrective).

SO1 — Injection SQL sur l'API REST Node.js (issu de SS1 / SR1)

A. Chemin d'attaque — Kill Chain

Phase	Étape	Action de l'attaquant	Technique / Outil
1	Reconnaissance	Scan automatisé de l'IP/domaine via Shodan, Censys. Identification des endpoints exposés, de la version Node.js. Détection de l'absence de WAF.	Shodan, Nmap, Wappalyzer. MITRE T1592
2	Armement	Préparation de payloads SQL adaptés à PostgreSQL : UNION-based, error-based, time-based blind. Utilisation de sqlmap.	sqlmap, Burp Suite. MITRE T1587
3	Livraison	Injection des payloads dans les paramètres de requête : /api/loan/apply?id_client=, /api/user/profile?phone=. Les tokens JWT à longue durée de vie permettent des sessions prolongées.	Requêtes HTTP malformées. MITRE T1190
4	Exploitation	Extraction de la table users (nom, téléphone, email, hash, données KYC biométriques, score crédit, historique de prêts). Escalade vers le schéma PostgreSQL complet via information_schema.	Dump SQL automatisé. MITRE T1005
5	Persistance	Création d'un compte admin fantôme dans la table users ou injection d'un JWT forgé si le secret de signature est extrait. Pose d'une webshell si une route d'upload non protégée existe.	MITRE T1078 — Valid Accounts
6	Exfiltration	Export complet de la base via canal out-of-band (DNS encoding, HTTPS vers serveur externe). Revente sur le darkweb. Déploiement optionnel de ransomware sur RDS.	MITRE T1048, T1486

B. Évaluation de l'impact DICT

Échelle d'impact : 1 = Négligeable | 2 = Limité | 3 = Important | 4 = Critique

Critère DICT	Impact (1–4)	Justification détaillée
Disponibilité (D)	2 / 4	L'API reste fonctionnelle pendant l'attaque SQLi. Une saturation est possible si l'attaquant multiplie les requêtes, provoquant un dégradé de service sans interruption totale.
Intégrité (I)	4 / 4	L'injection permet de modifier les montants de crédits accordés, les scores, les statuts de remboursement, et d'insérer de faux enregistrements. Atteinte directe à la fiabilité du portefeuille de créances (VM2 — criticité très haute).
Confidentialité (C)	4 / 4	Exfiltration complète : données KYC (identité, biométrie), scoring crédit, historique de prêts, numéros de téléphone. Violation grave de la Loi n°2009-09 APDP et obligation BCEAO.
Traçabilité (T)	3 / 4	Si CloudTrail n'est pas configuré pour journaliser les appels API applicatifs et si les logs Node.js ne sont pas centralisés dans un SIEM, l'attaquant peut opérer sans générer d'alerte.

C. Calcul de criticité et positionnement

Paramètre	Valeur	Commentaire
Vraisemblance (V) — Atelier 3	3 / 4	API REST exposée = cible standard des cybercriminels. Injections SQL toujours classées OWASP Top 1.
Impact maximal retenu (I)	4 / 4	Maximum entre D=2, I=4, C=4, T=3 → impact dominant = 4
Criticité = V × I	12 / 16	CRITIQUE — Traitement prioritaire.

D. Mesures de sécurité proposées

Mesure PRÉVENTIVE : Migration intégrale vers prepared statements (Knex.js / pg-promise). Validation et assainissement de toutes les entrées utilisateur (Joi ou Zod). Principe du moindre privilège sur les comptes PostgreSQL. Rotation forcée des tokens JWT toutes les 15 minutes avec refresh token à courte durée de vie (24h max). Revue de code sécurité (SAST : Semgrep, ESLint security rules) intégrée en CI/CD.

Mesure DÉTECTIVE / CORRECTIVE : Déploiement d’AWS WAF avec règles gérées OWASP (SQLi, XSS) devant l’ALB/API. Rate limiting applicatif (100 requêtes/minute par IP/token) via middleware Express. Centralisation des logs API dans CloudWatch Logs + alertes sur patterns SQL suspects. Test d’intrusion externe trimestriel (DAST). Plan de réponse à incident avec isolation automatique du service API en cas de détection d’exfiltration de masse.

SO2 — Exfiltration de données par un employé du backoffice (issu de SS2 / SR2)

A. Chemin d'attaque — Kill Chain

Phase	Étape	Action de l'attaquant	Technique / Outil
1	Préparation	L'employé cartographie ses accès : identification des tables disponibles, des fonctionnalités du backoffice accessibles sans restriction, et des absences de journalisation. Il teste la portée de ses permissions sans que cela déclenche d'alerte.	Accès légitime. Absence de baseline comportementale.
2	Collecte progressive	Export par lots de la table clients (KYC, numéros de téléphone, scoring), de la table loans et transactions sur son poste de travail via DBeaver ou psql. L'export est fractionné sur plusieurs jours pour rester sous les seuils suspects.	Abus de privilège. Absence de DLP. Pas de plafond de volume de requêtes.
3	Manipulation	Modification des scores de crédit pour approuver des prêts à des complices. Altération des statuts de remboursement pour masquer des impayés. Suppression de dossiers compromettants.	Accès en écriture sur la BD sans contrôle maker-checker.
4	Dissimulation	Compression et chiffrement des données exportées (zip avec mot de passe). Exfiltration via canaux personnels : clé USB, Google Drive perso, envoi par e-mail personnel ou messagerie chiffrée (Telegram).	Contournement de la politique SI par absence de DLP, blocage USB, filtrage web.
5	Impact	Revente de la base clients à un concurrent ou à des réseaux de fraude. Utilisation des données pour créer des dossiers de prêt fictifs. Violation APDP (notification sous 72h impossible). Risque de complicité de blanchiment (LCB-FT BCEAO).	MITRE T1078, T1052, T1485

B. Évaluation de l'impact DICT

Échelle d'impact : 1 = Négligeable | 2 = Limité | 3 = Important | 4 = Critique

Critère DICT	Impact (1–4)	Justification détaillée
Disponibilité (D)	1 / 4	L'exfiltration silencieuse ne perturbe pas le service. Le système reste disponible, ce qui est précisément ce qui la rend difficile à détecter.

Intégrité (I)	4 / 4	Modification de données de crédits (montants, scores, statuts), suppression de dossiers — corruption directe du portefeuille de créances (VM2 criticité très haute). Impact irréversible sans sauvegarde immuable.
Confidentialité (C)	4 / 4	La base complète des clients (KYC, données biométriques, historique financier, scoring) est compromise. Impact légal maximal au titre de l'APDP et de la BCEAO.
Traçabilité (T)	4 / 4	Sans pg_audit et sans SIEM, il est impossible de prouver quand, comment et par qui les données ont été extraites. Aucune preuve recevable pour une action judiciaire ou disciplinaire.

C. Calcul de criticité et positionnement

Paramètre	Valeur	Commentaire
Vraisemblance (V) — Atelier 3	3 / 4	Startup jeune, contrôles internes faibles, pression business sur les accès larges. Cas fréquents dans les fintech.
Impact maximal retenu (I)	4 / 4	Maximum entre D=1, I=4, C=4, T=4 → impact dominant = 4
Criticité = V × I	12 / 16	CRITIQUE — Traitement prioritaire.

D. Mesures de sécurité proposées

Mesure PRÉVENTIVE : Mise en œuvre du RBAC strict sur PostgreSQL : chaque rôle métier dispose uniquement des permissions nécessaires à sa fonction. Interdiction des `SELECT * FROM` sur les tables sensibles. Principe maker-checker sur les modifications de montants de crédit ou de score. Blocage des exports de masse non autorisés : désactivation du `COPY TO FILE`. Blocage des ports USB et filtrage de Google Drive sur les postes de travail (politique MDM). Signature d'une charte informatique avec clauses de confidentialité.

Mesure DÉTECTIVE / CORRECTIVE : Activation de l'extension `pg_audit` sur PostgreSQL avec journalisation de toutes les requêtes `SELECT` sur les tables sensibles. Envoi des logs vers AWS CloudWatch Logs (rétention 1 an minimum — exigence BCEAO). Mise en place d'un SIEM avec alertes sur volume d'exports inhabituel, connexions hors horaires, accès depuis IP non répertoriées. Revue trimestrielle des droits d'accès avec révocation immédiate des comptes inactifs ou des employés partis.

SO3 — Attaque DDoS sur l'infrastructure AWS (issu de SS3 / SR4)

A. Chemin d'attaque — Kill Chain

Phase	Étape	Action de l'attaquant	Technique / Outil
1	Reconnaissance	Identification de l'adresse IP publique de l'ALB AWS et du nom de domaine. Identification de l'unique région AWS utilisée (us-east-1) via DNS lookups et analyse des en-têtes HTTP.	nslookup, Shodan. MITRE T1590
2	Préparation	Location d'un botnet ou achat d'un service DDoS-as-a-Service (stresser). Choix du vecteur : volumétrique (UDP flood, ICMP flood) ou applicatif (HTTP flood sur <code>/api/loan/apply</code> pour épuiser les connexions Node.js).	Botnet commercial. MITRE T1498
3	Exécution	Lancement du flood vers l'ALB : saturation de la bande passante (volumétrique) ou épuisement du pool de connexions Node.js (applicatif Layer 7). Sans AWS Shield Advanced, le trafic malveillant n'est pas filtré automatiquement.	MITRE T1499 — Endpoint DoS

4	Impact	L'application mobile devient inaccessible pour les clients. Impossibilité de rembourser un crédit, perte de revenus, atteinte à la réputation et potentiellement à la conformité BCEAO (obligation de disponibilité du service de paiement).	Impact VM2 (disponibilité) et VM4 (réputation/conformité)
---	--------	--	---

B. Évaluation de l'impact DICT

Échelle d'impact : 1 = Négligeable | 2 = Limité | 3 = Important | 4 = Critique

Critère DICT	Impact (1–4)	Justification détaillée
Disponibilité (D)	4 / 4	Interruption totale du service mobile pour les clients, impossibilité de traiter les remboursements et les nouvelles demandes de crédit. Violation de l'obligation de continuité de service BCEAO.
Intégrité (I)	1 / 4	Une attaque DDoS pure ne modifie pas les données. L'intégrité des bases de données n'est pas affectée directement.
Confidentialité (C)	1 / 4	Pas de fuite de données lors d'une attaque DDoS classique. Risque marginal si l'attaque sert de diversion pour une intrusion simultanée.
Traçabilité (T)	2 / 4	AWS CloudTrail et les logs ALB permettent de journaliser l'attaque. L'identification des sources est difficile avec un botnet distribué.

C. Calcul de criticité et positionnement

Paramètre	Valeur	Commentaire
Vraisemblance (V) — Atelier 3	2 / 4	Possible mais moins fréquent dans le contexte béninois. Coût d'attaque DDoS faible mais cible délibérée reste risquée légalement pour l'attaquant.
Impact maximal retenu (I)	4 / 4	Impact dominant = Disponibilité = 4
Criticité = V × I	8 / 16	ÉLEVÉ — Traitement en priorité 2.

D. Mesures de sécurité proposées

Mesure PRÉVENTIVE : Activation d'AWS Shield Standard (inclus) + évaluation de l'upgrade vers AWS Shield Advanced (~3 000 USD/an) pour une protection volumétrique Layer 3/4 automatisée et une assistance DRT 24/7. Configuration de règles de rate limiting sur l'AWS WAF : limite de 1000 requêtes/5 min par IP vers l'API. Déploiement multi-AZ : répartition des serveurs d'application sur au moins deux zones de disponibilité AWS. Définition et test du PRA DDoS avec RTO < 30 minutes et RPO < 5 minutes.

Mesure DÉTECTIVE / CORRECTIVE : Configuration d'alarmes AWS CloudWatch sur les métriques ALB (RequestCount, TargetResponseTime, HTTP5XXCount) avec seuils d'alerte et escalade automatique (SNS → PagerDuty → astreinte). Activation de AWS GuardDuty pour la détection d'anomalies réseau au niveau du VPC. Souscription à une assurance cyber couvrant les pertes d'exploitation en cas d'indisponibilité prolongée.

SO4 — Exploitation d'une mauvaise configuration AWS (issu de SS4 / SR3)

A. Chemin d'attaque — Kill Chain

Phase	Étape	Action de l'attaquant	Technique / Outil
1	Accès initial	Un prestataire de développement externe avec accès temporaires au dépôt de code repère des secrets mal gérés : clés AWS IAM committées dans le code, variables d'environnement exposées dans un fichier .env versionné, ou bucket S3 de sauvegarde public par erreur.	Mauvaise gestion des secrets. MITRE T1552

2	Reconnaissance interne	Avec les clés IAM découvertes, l'attaquant énumère les ressources AWS accessibles : buckets S3, snapshots RDS, repositories ECR. Il identifie les sauvegardes de la BDD PostgreSQL stockées sur S3 sans chiffrement de bout-en-bout.	aws cli enumerate. MITRE T1580
3	Exfiltration	Téléchargement du code source de l'API Node.js et du module de scoring depuis le dépôt. Accès aux snapshots RDS pour reconstituer la base de données clients. Téléchargement des documents KYC depuis S3.	aws s3 cp, aws rds restore. MITRE T1530
4	Porte dérobée	Si le prestataire dispose d'accès au pipeline CI/CD, introduction d'une backdoor dans le code déployé en production (dependency confusion, injection dans le Dockerfile) pour maintenir un accès persistant après la fin du contrat.	MITRE T1195 — Supply Chain Compromise
5	Impact	Le concurrent reproduit l'algorithme de scoring (perte d'avantage concurrentiel), utilise la base clients pour du démarchage direct ou revend les données. Impact sur VM4 (réputation, valeur différenciante) et VM1 (confidentialité des données clients).	Impact VM1 + VM4 (Algorithme de scoring — criticité haute)

B. Évaluation de l'impact DICT

Échelle d'impact : 1 = Négligeable | 2 = Limité | 3 = Important | 4 = Critique

Critère DICT	Impact (1–4)	Justification détaillée
Disponibilité (D)	2 / 4	Risque d'indisponibilité si une backdoor est activée ou si des ressources AWS sont supprimées. En mode espionnage pur, la disponibilité n'est pas impactée.
Intégrité (I)	3 / 4	Si une backdoor est introduite dans le pipeline CI/CD, le code déployé peut être modifié silencieusement, affectant la fiabilité du service de scoring et du moteur d'octroi.
Confidentialité (C)	4 / 4	Exfiltration complète du code source de l'algorithme de scoring (actif stratégique clé) et potentiellement de la base clients via les sauvegardes S3. Atteinte directe à la valeur métier VM4 et VM1 (données personnelles APDP).
Traçabilité (T)	3 / 4	Sans AWS CloudTrail actif sur S3 et IAM, les téléchargements frauduleux ne laissent pas de trace. La détection post-incident est rendue difficile si les logs ne sont pas centralisés.

C. Calcul de criticité et positionnement

Paramètre	Valeur	Commentaire
Vraisemblance (V) — Atelier 3	2 / 4	Cible délibérée mais espionnage industriel exige des ressources. Startup jeune, pas encore systématiquement ciblée. (Réévaluée de 4/4 à 2/4 dans la justification finale de l'Atelier 3.)
Impact maximal retenu (I)	4 / 4	Impact dominant = Confidentialité = 4
Criticité = V × I	8 / 16	ÉLEVÉ — Traitement en priorité 2.

D. Mesures de sécurité proposées

Mesure PRÉVENTIVE : Audit immédiat de tous les buckets S3 : blocage public, chiffrement obligatoire SSE-KMS, politique IAM de moindre privilège. Rotation et révocation de toutes les clés IAM actuelles. Migration vers AWS Secrets Manager pour la gestion de TOUTES les credentials. Interdiction de commiter des secrets dans le code : mise en place de git-secrets ou de TruffleHog dans le pipeline CI/CD. Accès des prestataires externes : comptes IAM temporaires avec permissions minimales, rotation automatique des clés après fin de mission. Activation de AWS MFA obligatoire pour tous les accès AWS Console.

Mesure DÉTECTIVE / CORRECTIVE : Activation d'AWS Config avec règles de détection des mauvaises configurations (buckets S3 publics, politiques IAM trop permissives). Activation d'AWS GuardDuty pour la détection de comportements IAM anormaux. Revue de code obligatoire avec deux approbateurs avant tout merge en production. Analyse SCA (Software Composition Analysis) des dépendances. Audit de sécurité externe annuel couvrant la configuration AWS (AWS Well-Architected Review).

Synthèse des criticités — Atelier 4

SO	Scénario opérationnel	D	I	C	T	Vrais.	Impact max.	Criticité
SO1	Injection SQL API REST	2	4	4	3	3/4	4/4	12/16 ■
SO2	Exfiltration interne backoffice	1	4	4	4	3/4	4/4	12/16 ■
SO3	Attaque DDoS infrastructure	4	1	1	2	2/4	4/4	8/16 ■■
SO4	Config. AWS mal sécurisée	2	3	4	3	2/4	4/4	8/16 ■■

Atelier 5 — Traitement des risques & synthèse

Objectif de l'Atelier 5 : Sur la base des criticités établies en Atelier 4, définir une stratégie de traitement pour chaque risque, élaborer un Plan de Traitement des Risques (PTR) priorisé et chiffré, calculer le risque résiduel, et présenter la cartographie finale des risques sur une matrice 4×4.

5.1 Stratégies de traitement des risques

SO	Scénario	Criticité	Stratégie	Justification du choix
SO1	Injection SQL API REST	12/16 Critique	RÉDUIRE	Les mesures techniques (prepared statements, WAF) sont directement implémentables. Le risque zéro est impossible sur une API internet, mais la réduction de V de 3 à 1 est réaliste. Éviter (retrait de l'API) n'est pas une option : c'est le cœur du service.
SO2	Exfiltration interne backoffice	12/16 Critique	RÉDUIRE	Le RBAC, pg_audit et le DLP sont des mesures organisationnelles et techniques à coût maîtrisé. La menace interne ne peut pas être éliminée mais peut être fortement réduite. Transférer est impossible : aucune assurance ne couvre une exfiltration délibérée par un employé.
SO3	DDoS infrastructure AWS	8/16 Élevé	TRANSFÉRER + RÉDUIRE	AWS Shield Advanced constitue un transfert partiel vers AWS (DRT). La souscription à une assurance cyber transfère le risque financier résiduel. Des mesures de réduction complémentaires (rate limiting, multi-AZ) abaissent la vraisemblance.
SO4	Config. AWS mal sécurisée	8/16 Élevé	RÉDUIRE	Le hardening AWS (Secrets Manager, MFA IAM, AWS Config) est un investissement à ROI immédiat : il protège simultanément contre SO4 et renforce la posture globale. Le coût est inférieur au préjudice d'une exfiltration de l'algorithme de scoring.

5.2 Plan de Traitement des Risques (PTR) priorisé

Prio	SO	Actions de traitement	Resp.	Échéance	Coût estimé	KPI de suivi
P1	SO1	• Migration intégrale vers prepared statements (Knex.js) • Validation des entrées avec Joi/Zod sur tous les endpoints • Déploiement AWS WAF avec règles OWASP gérées • Rate limiting 100 req/min/IP via middleware Express • Rotation JWT toutes les 15 min + refresh tokens 24h • SAST (Semgrep) intégré en CI/CD bloquant • Test de pénétration externe (DAST) dans les 30 jours	CTO / Lead Dev	J+15 (P1-P2) J+21 (P3-P5) J+30 (D)	~400 USD/mois (WAF) + 2j/h dev	0 vuln. SQLi en pentest. WAF actif.
P1	SO2	• Audit et redéfinition des rôles PostgreSQL (RBAC strict) • Activation pg_audit avec journalisation sur tables sensibles • Envoi logs vers CloudWatch Logs (rétention 1 an min. BCEAO) • Mise en œuvre du principe maker-checker dans le backoffice • Blocage USB + filtrage sortant (Google Drive, Mega) sur les postes • Alertes SIEM sur exports > 500 lignes/session hors heures • Revue trimestrielle des droits d'accès + révocation comptes inactifs	DSI / DBA / RH	J+20 (P1-P3) J+45 (P4-P5) J+60 (D)	~250 USD/mois (SIEM) + 3j/h DBA	100% c omptes RBAC. Logs actifs.

P2	SO4	- Audit complet des buckets S3 (blocage accès public, chiffrement SSE-KMS) • Révocation et rotation de toutes les clés IAM → Secrets Manager • Ajout de git-secrets / TruffleHog dans le pipeline CI/CD • Accès prestataires : IAM temporaire + MFA + revue à chaque fin de sprint - AWS MFA obligatoire pour tous les comptes IAM humains • AWS Config avec règles détectant buckets publics et politiques IAM larges • AWS GuardDuty activé (anomalies comportement IAM)	DevOps / CTO	J+15 (P1-P2) J+30 (P3-P5) J+45 (D)	~150 USD/mois + 2j/h DevOps	0 secret dans le code. 100% MFA IAM.
P3	SO3	Évaluation et activation AWS Shield Advanced • Déploiement multi-AZ (us-east-1a + us-east-1b) pour ALB et EC2 • Définition et test du PRA DDoS (RTO < 30 min) • Souscription assurance cyber couvrant pertes d'exploitation DDoS • Alarmes CloudWatch sur HTTP5XX, RequestCount (seuils alertes) • GuardDuty pour détection anomalies réseau VPC	CTO / CFO	J+30 (P1-P2) J+60 (P3-P4) J+30 (D)	~3 000 USD/an (Shield) + assurance ~500 USD/an	RTO testé. Shield actif.

Budget total du PTR : ~800 USD/mois en coût opérationnel récurrent (WAF + SIEM + Secrets Manager + Config) + ~3 500 USD/an en investissements ponctuels (Shield Advanced, assurance, pentest) + ~7 jours.hommes internes pour la mise en œuvre initiale. Ce budget est proportionné à la valeur des actifs protégés (base clients + algorithme de scoring).

5.3 Comparaison risque initial vs risque résiduel

SO	Scénario	V init.	I init.	Crit. init.	V résid.	I résid.	Crit. résid.	Mesures clés ayant réduit V	Niveau
SO 1	Injection SQL API REST	3	4	12 CRITIQUE	1	2	2	Prepared stmts + WAF + SAST + Pentest	FAIBLE ✓
SO 2	Exfiltration interne	3	4	12 CRITIQUE	1	2	2	RBAC + pg_audit + SIEM + DLP + Maker-checker	FAIBLE ✓
SO 3	DDoS infrastructure	2	4	8 ÉLEVÉ	1	2	2	Shield Advanced + Multi-AZ + Rate limiting + PRA	FAIBLE ✓
SO 4	Config. AWS mal sécurisée	2	4	8 ÉLEVÉ	1	2	2	Secrets Manager + MFA + Config + GuardDuty + RBAC IAM	FAIBLE ✓

Note de lecture : La réduction de la vraisemblance de 3 ou 2 vers 1 traduit l'efficacité des mesures préventives rendant l'attaque beaucoup plus difficile à exécuter. La réduction de l'impact de 4 vers 2 traduit la capacité des mesures de détection et de réponse à limiter les dommages même si une attaque partielle réussit.

5.4 Cartographie finale des risques — Matrice 4x4

	V = 1 Minime	V = 2 Significatif	V = 3 Fort	V = 4 Maximal
I = 4 Critique		SO3 init. SO4 init.	SO1 init. SO2 init.	
I = 3 Grave				

I = 2 Significatif	SO1 résid. ✓ SO2 résid. ✓ SO3 résid. ✓ SO4 résid. ✓			
I = 1 Mineur				

Couleur	Signification
Rouge foncé	Zone CRITIQUE : action immédiate obligatoire. SO1 et SO2 y étaient positionnés initialement (criticité 12/16).
Orange	Zone ÉLEVÉE : traitement prioritaire. SO3 et SO4 initiaux (criticité 8/16).
Jaune	Zone MODÉRÉE : surveillance et mesures proportionnées.
Vert	Zone ACCEPTABLE : risque résiduel après PTR. Les 4 scénarios convergent ici après traitement (criticité résiduelle 2/16).

5.5 Synthèse et conclusion

Bilan : L'analyse EBIOS RM complète menée sur le SI de la startup de microcrédit mobile a permis d'identifier 4 scénarios de risques significatifs à partir de 4 sources de risques, articulés autour de 5 valeurs métier critiques. Les deux risques les plus critiques (SO1 : injection SQL et SO2 : exfiltration interne, criticité 12/16) font l'objet d'un traitement prioritaire par réduction, ramenant leur criticité résiduelle à 2/16.

Principaux enseignements de l'analyse :

Surface d'attaque principale	L'API REST Node.js est la cible naturelle des cybercriminels. Son durcissement (prepared statements, WAF, rotation JWT) constitue la mesure de plus grand impact avec le meilleur ROI.
Menace interne	La menace interne (SO2) est la plus difficile à traiter car elle exploite des accès légitimes. Elle requiert une approche combinant technique (RBAC, audit logging) et organisationnel (maker-checker, charte SI, revue des droits). Sans ces mesures, toute violation serait juridiquement intraitable faute de preuve.
Infrastructure AWS	L'infrastructure AWS présente des risques de configuration sous-estimés (SO4) mais corrigeables rapidement via les outils natifs AWS (Secrets Manager, Config, GuardDuty, MFA IAM) à coût proportionnel.
Risque DDoS	Le risque DDoS (SO3) est le seul dont la stratégie de traitement est partiellement transférée (Shield Advanced + assurance cyber), acceptant un risque résiduel faible proportionnel au contexte béninois.
Conformité réglementaire	La conformité réglementaire (APDP + BCEAO) est un fil directeur transversal : toutes les mesures du PTR répondent simultanément à des exigences de sécurité et de conformité, créant un double bénéfice.

Recommandations de suivi :

- Revue EBIOS RM semestrielle : réexaminer les sources de risques et les scénarios à chaque évolution majeure du SI (nouvelle fonctionnalité, nouveau prestataire, changement de réglementation).
- Audit de conformité annuel BCEAO/APDP avec rapport à la direction et au conseil d'administration.
- Exercice de simulation d'incident (tabletop exercise) biannuel simulant SO1 (injection) et SO2 (exfiltration interne) pour tester les procédures de réponse et la capacité de notification sous 72h exigée par l'APDP.
- Intégration de la sécurité dans le cycle de développement (DevSecOps) : SAST en CI/CD, revue de code sécurité obligatoire, formation développeurs aux OWASP Top 10 une fois par an.

Après mise en œuvre intégrale du PTR :

Les 4 scénarios passent de zones CRITIQUE / ÉLEVÉ à la zone ACCEPTABLE (criticité 2/16)

Budget total : ~800 USD/mois + ~3 500 USD/an | Délai de mise en œuvre : 60 jours